

SIMATS ENGINEERING

ASSESSMENT TOOL 3 – ANSWER SCRIPT

Course Code:	CSA51	Course Name:	Cryptography and Network Security
Register No:	192521079	Course Outcome:	CO5 (BL5, BL6)

Annexure A – Mock Interview (20 Questions, 1 Mark Each)

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.

SSL (especially v2/v3) has weak cipher support (RC4, weak MACs), is vulnerable to known exploits such as POODLE and BEAST, uses a weaker handshake with fewer integrity checks, and has been deprecated by all major browsers. TLS fixes these by supporting stronger, modern cipher suites (AES-GCM, ChaCha20), a more secure handshake with better key derivation (HKDF in TLS 1.3), forward secrecy through ephemeral Diffie-Hellman, and protection against downgrade and padding-oracle attacks — making it the current industry standard.

2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.

The client sends a ClientHello with supported ciphers and a random value; the server responds with its certificate and chosen cipher. The client verifies the certificate, then generates a pre-master secret, encrypts it with the server's public key, and sends it over. Both sides independently combine the client random, server random, and pre-master secret through a key-derivation function to compute an identical symmetric session key, which is then used to encrypt all further communication — so the key itself never travels in plaintext.

3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.

SSL relies on older, weaker ciphers (RC4, DES) and a simpler MAC construction, offering no forward secrecy in most configurations. TLS supports modern AEAD ciphers (AES-GCM, ChaCha20-Poly1305), enforces forward secrecy via ephemeral key exchange, uses HMAC-based integrity checks, and in TLS 1.3 reduces the handshake to one round trip while removing legacy weak algorithms entirely — improving both security and performance.

4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?

If a client fails to check the certificate's chain of trust, expiry, hostname match, or revocation status, an attacker can present a self-signed or stolen certificate and perform a man-in-the-middle attack — intercepting and decrypting traffic the user believes is secure, capturing credentials or payment data while the browser shows a false 'secure' indicator.

5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.

A digital certificate binds a public key to an identity (domain/organization) and is signed by a trusted Certificate Authority (CA). During the handshake, the client verifies this CA signature using the CA's known public key, confirming the server is who it claims to be before any sensitive data or session key is exchanged — preventing impersonation.

6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.

SET uses dual signatures so the merchant sees only order information and the bank sees only payment information — neither party sees the other's data. All three parties (cardholder, merchant, bank) hold digital

certificates, and the transaction is encrypted and signed end-to-end, ensuring the merchant never directly accesses the customer's raw card number.

7. Evaluate the limitations of the SET protocol in current online payment systems.

SET requires special digital-wallet client software that is not natively supported by modern browsers, has high implementation complexity due to its three-way PKI, involves significant computational and transaction latency overhead, and never achieved wide industry adoption — which is why it has been effectively replaced by TLS combined with tokenization and 3-D Secure.

8. Compare SET protocol with TLS-based payment security and justify which is more practical today.

SET offers strong non-repudiation and dual-party privacy but is complex, slow, and needs special client software; TLS is simple, universally supported, and fast, though by itself it only secures the transport channel rather than the transaction semantics. TLS combined with tokenization and 3-D Secure is more practical today because it delivers comparable protection with far lower complexity and full browser/mobile compatibility.

9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.

If an infected spreadsheet attachment corrupts other files only after a user opens it, that is a virus (needs a host file and user action). If the same program instead spreads itself automatically across the network without any user opening anything, it is a worm. If the program disguises itself as legitimate software and the user knowingly installs it, only for it to open a hidden backdoor, it is a Trojan.

10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.

Immediately isolate infected subnets via network segmentation/VLAN quarantine, deploy IDS/IPS to detect and block the propagation traffic pattern, patch the exploited vulnerability network-wide, disable unnecessary services (e.g., SMB) that enable lateral movement, and restore affected systems from clean backups.

11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.

A Trojan disguised as a free utility tool, once installed, can silently exfiltrate saved passwords and documents (breaking confidentiality) and modify system files or install additional malware (breaking integrity) — all while appearing to function normally, making it especially dangerous since the user has no reason to suspect it.

12. Compare viruses, worms, and Trojans based on propagation method and system impact.

A virus attaches to a host file and spreads only when a user executes that file, mainly corrupting or infecting other files. A worm self-replicates across networks with no user interaction, primarily consuming bandwidth and system resources while spreading rapidly. A Trojan does not self-propagate at all — it relies on the user willingly installing it under a false identity, and its impact is typically data theft or creating a backdoor.

13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.

A packet-filtering firewall inspects each packet's header (source/destination IP, port, protocol) against a static rule set and allows or drops it, without tracking connection state. Its limitations include inability to detect application-layer attacks, no awareness of ongoing sessions (making it vulnerable to spoofing), and no protection against threats hidden inside allowed ports (e.g., malicious payloads over port 443).

14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

For a web server, allow inbound TCP traffic only on ports 80/443 from any source, allow inbound SSH (port 22) only from the admin's known IP range, block all other inbound ports by default, and allow outbound traffic

needed for updates/logging — implementing a default-deny policy with explicit allow rules for required services only.

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.

Stateful firewalls track the full context of each connection (TCP handshake state, sequence numbers), so they can automatically allow legitimate return traffic and reject packets that don't belong to a known session — this blocks spoofed and out-of-state packets that a stateless firewall (which checks each packet in isolation) would let through, making stateful inspection significantly more effective against modern attacks.

16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

Packet-filtering firewalls are fast but shallow; stateful firewalls add connection-awareness; proxy/application-layer firewalls inspect content but add latency; Next-Generation Firewalls (NGFW) combine stateful inspection, deep packet inspection, intrusion prevention, and application awareness in one device. For an enterprise network facing both external and insider threats, an NGFW is the most suitable choice since it provides layered protection without requiring multiple separate appliances.

17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.

Signature-based detection compares traffic against a database of known attack patterns, offering high accuracy for known threats but no protection against new ones. Anomaly-based detection builds a baseline of normal traffic and flags significant deviations, catching novel/zero-day attacks but with a higher risk of false positives. Combining both gives reliable detection of known attacks plus coverage for unknown ones.

18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.

The IDS/IPS monitors traffic volume and connection-rate patterns in real time; when a sudden surge of requests from many distributed sources is detected (matching a DDoS signature or anomaly threshold), the IPS automatically rate-limits or blacklists the offending source IPs, drops malformed/flood packets inline, and can trigger upstream traffic scrubbing or a CDN-based mitigation service, while logging the attempt for analysis.

19. Evaluate the differences between IDS and IPS in terms of response to detected threats.

An IDS is passive — it monitors traffic out-of-band and only generates alerts for an analyst to act on, so malicious traffic still reaches its target. An IPS is active and sits inline in the traffic path, so it can automatically drop or block malicious packets in real time as they are detected, providing immediate prevention rather than just detection — at the cost of a small risk of blocking legitimate traffic if misconfigured.

20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

Combine signature-based and anomaly-based detection with confidence scoring, continuously retrain the anomaly baseline using the organization's own verified-normal traffic, correlate related low-level alerts into single incidents via a SIEM to cut redundant noise, tune detection thresholds specifically for the network's traffic profile, and route low-confidence anomalies to monitoring rather than auto-alerting — together lowering false positives while keeping true-attack detection accuracy high.